MCP (Model Context Protocol) セキュリティ懸念調査

調査トピック: MCPのセキュリティリスク（インジェクション、権限、データ漏洩）
実行日時: 2026-03-14
ツール: AI Research Agent v2.1.0

Executive Summary（エグゼクティブサマリー）

- **MCPの現状**: LLMとツールを接続する標準プロトコルとして普及中だが、構造的脆弱性を抱える
- **最大のリスク**: 「Lethal Trifecta（致死的な3要素）」によるデータ流出
- **攻撃手法の高度化**: プロンプトインジェクションやツール汚染（Tool Poisoning）
- **現状認識**: OWASPが「MCP Top 10」を策定、CVEも確認され実害フェーズへ
- **緊急対策**: 最小権限、Human-in-the-Loop、サンドボックス化が必須

Finding 1: プロンプトインジェクションとツール汚染

攻撃者はツール定義や外部データを操作し、実行を強制可能

- **Claim**: LLMの性質を悪用し、ユーザーの同意なしにツールを実行させる
- **Evidence**:
  - **Tool Poisoning**: ツール説明文（description）に悪意ある命令を埋め込む
  - **Indirect Prompt Injection**: メール・ファイル等の外部入力に命令を隠蔽
- **Confidence**: **High** (OWASP MCP Top 10 #3, #6)

Finding 2: データ漏洩リスク (Lethal Trifecta)

3つの要素が揃うとデータ流出リスクが極大化する

- **Claim**: 信頼できないコンテンツと外部送信手段の組み合わせは危険
- **Evidence**: **Lethal Trifecta**（以下の3要素の結合）
  i. **信頼できないコンテンツへのアクセス**（Web, メール等）
  ii. **機密データへのアクセス**
  iii. **外部への送信手段**（Side channel, API等）
- **Confidence**: **High** (Microsoft Developer Blog)

Finding 3: 過剰な権限とConfused Deputy

LLMが攻撃者の命令をユーザーの命令と誤認

- **Claim**: エージェントが「混乱した代理人（Confused Deputy）」となり権限を濫用
- **Evidence**:
  - 攻撃者のインジェクションにより、本来許可されていない操作を実行
  - 多くのMCP実装でツール権限が過剰に付与されている現状
- **Confidence**: **High/Medium**

Finding 4: プロトコル仕様の未成熟

認証・認可メカニズムの欠如

- **Claim**: MCP仕様レベルでのセキュリティ標準が不足している
- **Evidence**:
  - 接続するサーバーの正当性を検証するアテステーション機能の不足
  - 悪意あるMCPサーバーへの接続によるサプライチェーン攻撃リスク
- **Confidence**: **Medium** (Unresolved issues)

警告: 理論的リスクから実害へ

脆弱性は既に悪用可能なフェーズにある

- **CVEの出現**: CVE-2025-6514, CVE-2025-49596 等が既に登録済み
- **OWASP MCP Top 10 (2025)**: 脆弱性分類が体系化された
- **実被害**: 理論上の懸念ではなく、実際の攻撃ベクターとして機能
- **組織対応**: 今すぐ多層防御を実装する必要がある

Confidence Summary（信頼性サマリー）

検証結果: PARTIAL（一部根拠不足あり）

指標	件数	備考
High Confidence	18	複数ソースでの裏付けあり
Medium Confidence	15	信頼できるソースはあるが補強不足
Low Confidence	0	-
Evidenceなし	2	一部主張に根拠が紐付いていない

制限事項と未解決課題

- **検知の困難さ**: 自然言語による攻撃のため、従来のファイアウォールでは防げない
- **プロトコルの限界**: 仕様レベルでの認証・認可が未解決
- **調査の限界**: 本レポートの一部Evidenceが欠落している（要人間検証）

結論と推奨アクション

MCPは有用だが、セキュリティモデルの再考が必要

1. **最小権限の原則**: 必要最低限のツールのみを読み込ませる
2. **Human-in-the-Loop**: 重要な操作（書き込み・送信）前に必ず人間が承認する
3. **サンドボックス化**: MCPサーバーやエージェントの実行環境を隔離する
4. **入力検証**: ツール側でLLMからの入力を厳格にバリデーションする